

Claims-Based Authentication

Table of Contents

- Table of Contents
- ECAS Server can act as a Security Token Service (STS)
- ECAS Server can act as an Identity Provider (IP, IdP)
- ECAS Server can act as a Service Provider (SP)
- SharePoint integration
- ECAS Mockup Server
- Claims
- ECAS ACCEPTANCE environment
- ECAS Mockup Server

ECAS Server can act as a Security Token Service (STS)

ECAS Server implements the [WS-Federation: Passive Requestor Profile](#).

This specification can also be found in the SVN repository: [WS-Federation Passive Requestor Profile.pdf](#).

ECAS Server signs its security token requests (RST) and responses (RSTR) with the following certificate:

- [ecas-acceptance-sts.pem.cer](#)
- [ecas-test-ca-2015.cer](#)

The federation metadata for EU Login acceptance is accessible via HTTP:

- from outside the European Commission network: <https://ecas.acceptance.ec.europa.eu/cas/adfs/federationmetadata/ecas-acceptance-ec-europa-eu.xml>
- from inside the EC network: https://ecasa.cc.cec.eu.int:7002/cas/adfs/federationmetadata/ecasa-cc-cec-eu-int_7002.xml

ECAS Server can act as an Identity Provider (IP, IdP)

Example: SharePoint 2010 (Service Provider) communicates with ECAS Server (Identity Provider).

To add ECAS as Identity Provider in a Service Provider, the URL <https://ecasa.cc.cec.eu.int:7002/cas/login> must be used to send the request for the security token (RST).

To add the Service Provider configuration to ECAS Server, we need:

- the **realm** that will be used as the unique name of your configuration
e.g. `urn:myecascollab.cp-dev1.cec.eu.int:ecas`
or <https://ecasportal.cc.cec.eu.int/InternalSite/ADFSv2Sites/ecasd>
- the **URL** to which ECAS Server must post the security token response (RSTR)
e.g. http://myecascollab.cp-dev1.cec.eu.int/_trust
or <https://ecasportal.cc.cec.eu.int/InternalSite/ADFSv2Sites/ecasd>
- the **claims** you would like to receive;
- one or more authentication **strenght(s)** accepted by your application. Strenghts currently compatible with SAML are PASSWORD, PASSWORD_SMS, PASSWORD_TOKEN, PASSWORD_SOFTWARE_TOKEN, PASSWORD_MOBILE_APP and STORK;
- if you want activate the **strength upgrade** functionality (only possible if at least one multi-factor strength and at least one single-factor strength are accepted). Strength upgrade forces 2-factor authentication for users outside the trusted networks of the EU Institutions.

ECAS Server can act as a Service Provider (SP)

Example: ECAS Server (Service Provider) communicates with AD FS 2.0 (Identity Provider).

To add ECAS as Service Provider in an Identity Provider, the URL https://ecasa.cc.cec.eu.int:7002/cas/_trust must be used to send the security token response (RSTR).

To add the Identity Provider configuration to ECAS Server, we need:

- the **realm** that will be used as the unique name of the ECAS Server configuration,
e.g. `urn:ecasa.cc.cec.eu.int:7002:adfs`

- the **URL** to which ECAS Server must send the request for the security token (RST), e.g. http://myecascollab.cp-dev1.cec.eu.int/_trust
- the Identity Provider **signing certificate** (chain) in .pem format (Privacy Enhanced Mail, Base64 encoded DER certificate, enclosed between "-----BEGIN CERTIFICATE-----" and "-----END CERTIFICATE-----")
- the **claims** ECAS Server should receive and pass on

SharePoint integration



Disclaimer



1. **DIGIT does not recommend the deployment of SharePoint.**
2. **SharePoint is a product that is currently not supported by the DIGIT product management and its use is limited to the implementation of MyIntraComm.**
3. **What is described below only represents a small part of the changes that need to be achieved in order to benefit from a successful integration with ECAS. The complete and large set of changes is not available in any consolidated bundle.**
4. **The integration of SharePoint with ECAS involves a continuous and strong maintenance in addition to a very specific and cross domain expertise.**
5. **DIGIT does not offer a service to support the integration of ECAS with SharePoint so the implementation made by a DG or a team different from *MyIC technical team* will be done at their own risk and responsibility.**

There are two ways to authenticate SharePoint with ECAS:

1. Using claims-based authentication where ECAS will act and behave exactly like an ADFSv2 (Active Directory Federation Services) exposing the WS-Trust and WS-Federation protocols. If you decide to go that way you should simply follow the instructions from Microsoft explaining how to integrate SharePoint with ADFS (e.g. [Configuring SharePoint 2010 and ADFS v2 End to End](#)) For the SharePoint part, see <http://info.summit7systems.com/blog/beginners-guide-to-claims-based-authentication-ad-fs-3-0-and-sharepoint-2013-part-iii-configuring-sharepoint-2013-for-ad-fs>
2. Using a CAS client, which has implications on the features exposed by SharePoint but allows circumventing problems in the session management of SharePoint in certain conditions (clustering and SSL). You will find more information on the Jasig website that maintains CAS (e.g. [CASifying SharePoint & ASP.NET Web Sites](#)).

The Commission intranet ([My IntraComm](#)) relies on the second option.

If you choose the second option (CAS Client), please take into account that the changes you will have to perform in your SharePoint will go beyond authentication.

You will also have to work on other aspects as:

- Internal claims augmentation.
- Redefinition of the authorization at the corporate level.
- Partial rewriting of the people picker.
- Reimplementation of the user provisioning.
- Redesign of the access zones.

... among other elements.

Some more remarks:

1. The authentication mechanism in SharePoint will go always through *authentication.aspx*, an OOB page that will determine the login page to use on the basis if the authentication provider selected for the zone.
2. In the case of the Form Based Authentication provider, this page is the *trust.aspx*.
3. You have to re-implement the methods in a new *trust.aspx* page inheriting from the login page:
 1. For the login method, you will have to perform a call to the login page of ECAS with the corresponding security strengths you choose.
 2. Same applies to the logout method.
 3. Same applies to the validate method.

In case you plan to deploy a SharePoint 2013 platform, a pure claims based authentication should work but then you will need to set up and configure a distributed cached server to cache your authenticated sessions.

It is highly recommended that you plan in advance the security schema you plan to apply before start developing any version of your customizations aimed at being deployed in a production environment.

ECAS Mockup Server

We provide an ECAS Mockup Server (available [here](#)) that you can use for testing purposes. It implements claims-based authentication but it requires that we generate a certificate for the host you will be using.

Claims

ECAS Server supports any claim you could want to map.

The user attribute values which the ECAS server can use to populate your claims come from the ECAS directory, which contains the uid (unique user id), the moniker (username used to log in), the domain (user population), the email, the first name, the last name, the CUD groups, etc.

Conceptually-logical attribute-to-claim mappings are reflected into the existing Federation MetaData XML file (https://ecast.cc.cec.eu.int:7002/cas/adfs/federationmetadata/ecast-cc-cec-eu-int_7002.xml), however any possible mapping could be used to suit your needs.

The following claims are already configured in the ECAS server, even when no logical value exists in the ECAS server for the concept exposed by the given claim:

```
<claim>
  <name>age-18-or-over</name>
  <namespace>http://schemas.informationcard.net/@ics</namespace>
  <uri>http://schemas.informationcard.net/@ics/age-18-or-over/2008-11<
/uri>
</claim>
<claim>
  <name>age-21-or-over</name>
  <namespace>http://schemas.informationcard.net/@ics</namespace>
  <uri>http://schemas.informationcard.net/@ics/age-21-or-over/2008-12<
/uri>
</claim>
<claim>
  <name>authenticationinstant</name>
  <namespace>http://schemas.microsoft.com/ws/2008/06/identity/claims<
/namespace>
  <uri>http://schemas.microsoft.com/ws/2008/06/identity/claims
/authenticationinstant</uri>
</claim>
<claim>
  <name>authenticationmethod</name>
  <namespace>http://schemas.microsoft.com/ws/2008/06/identity/claims<
/namespace>
  <uri>http://schemas.microsoft.com/ws/2008/06/identity/claims
/authenticationmethod</uri>
</claim>
```

```
<claim>
  <name>CommonName</name>
  <namespace>http://schemas.xmlsoap.org/claims</namespace>
  <uri>http://schemas.xmlsoap.org/claims/CommonName</uri>
</claim>
<claim>
  <name>country</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/country<
/uri>
</claim>
<claim>
  <name>dateofbirth</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/dateofbirth<
/uri>
</claim>
<claim>
  <name>denyonlyprimarygroupsid</name>
  <namespace>http://schemas.microsoft.com/ws/2008/06/identity/claims<
/namespace>
  <uri>http://schemas.microsoft.com/ws/2008/06/identity/claims
/denyonlyprimarygroupsid</uri>
</claim>
<claim>
  <name>denyonlyprimarysid</name>
  <namespace>http://schemas.microsoft.com/ws/2008/06/identity/claims<
/namespace>
  <uri>http://schemas.microsoft.com/ws/2008/06/identity/claims
/denyonlyprimarysid</uri>
</claim>
<claim>
  <name>denyonlysid</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/denyonlysid<
/uri>
</claim>
<claim>
  <name>department</name>
  <namespace>http://schemas.ec.europa.eu/identity/claims</namespace>
  <uri>http://schemas.ec.europa.eu/identity/claims/department</uri>
</claim>
<claim>
  <name>emailaddress</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims
/emailaddress</uri>
</claim>
<claim>
```

```
<name>EmailAddress</name>
<namespace>http://schemas.xmlsoap.org/claims</namespace>
<uri>http://schemas.xmlsoap.org/claims/EmailAddress</uri>
</claim>
<claim>
  <name>employeeType</name>
  <namespace>http://schemas.ec.europa.eu/identity/claims</namespace>
  <uri>http://schemas.ec.europa.eu/identity/claims/employeeType</uri>
</claim>
<claim>
  <name>givenname</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/givenname<
/uri>
</claim>
<claim>
  <name>Group</name>
  <namespace>http://schemas.xmlsoap.org/claims</namespace>
  <uri>http://schemas.xmlsoap.org/claims/Group</uri>
</claim>
<claim>
  <name>groupsid</name>
  <namespace>http://schemas.microsoft.com/ws/2008/06/identity/claims<
/namespace>
  <uri>http://schemas.microsoft.com/ws/2008/06/identity/claims/groupsid<
/uri>
</claim>
<claim id="IDENTITY_PROVIDER">
  <name>identityprovider</name>
  <namespace>http://schemas.microsoft.com/accesscontrolservice/2010/07
/claims</namespace>
  <uri>http://schemas.microsoft.com/accesscontrolservice/2010/07/claims
/identityprovider</uri>
</claim>
<claim>
  <name>locality</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/locality<
/uri>
</claim>
<claim>
  <name>mobilephone</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/mobilephone<
/uri>
</claim>
<claim>
  <name>name</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
```

```
<uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/name</uri>
</claim>
<claim>
  <name>nameidentifier</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims
/nameidentifier</uri>
</claim>
<claim id="ORGANISATION">
  <name>organisation</name>
  <namespace>http://schemas.ec.europa.eu/identity/claims</namespace>
  <uri>http://schemas.ec.europa.eu/identity/claims/organisation</uri>
</claim>
<claim>
  <name>otherphone</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/otherphone<
/uri>
</claim>
<claim>
  <name>postalcode</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/postalcode<
/uri>
</claim>
<claim>
  <name>privatepersonalidentifier</name>
  <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
  <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims
/privatepersonalidentifier</uri>
</claim>
<claim>
  <name>primarygroupsid</name>
  <namespace>http://schemas.microsoft.com/ws/2008/06/identity/claims<
/namespace>
  <uri>http://schemas.microsoft.com/ws/2008/06/identity/claims
/primarygroupsid</uri>
</claim>
<claim>
  <name>primarysid</name>
  <namespace>http://schemas.microsoft.com/ws/2008/06/identity/claims<
/namespace>
  <uri>http://schemas.microsoft.com/ws/2008/06/identity/claims
/primarysid</uri>
</claim>
<claim>
  <name>role</name>
  <namespace>http://schemas.microsoft.com/ws/2008/06/identity/claims<
/namespace>
```

```

        <uri>http://schemas.microsoft.com/ws/2008/06/identity/claims/role</uri>
    </claim>
    <claim>
        <name>stateorprovince</name>
        <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
        <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims
/stateorprovince</uri>
    </claim>
    <claim>
        <name>streetaddress</name>
        <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
        <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims
/streetaddress</uri>
    </claim>
    <claim>
        <name>surname</name>
        <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
        <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/surname<
/uri>
    </claim>
    <claim>
        <name>upn</name>
        <namespace>http://schemas.xmlsoap.org/ws/2005/05/identity/claims<
/namespace>
        <uri>http://schemas.xmlsoap.org/ws/2005/05/identity/claims/upn</uri>
    </claim>
    <claim>
        <name>UPN</name>
        <namespace>http://schemas.xmlsoap.org/claims</namespace>
        <uri>http://schemas.xmlsoap.org/claims/UPN</uri>
    </claim>
    <claim>
        <name>username</name>
        <namespace>http://schemas.informationcard.net/@ics</namespace>
        <uri>http://schemas.informationcard.net/@ics/username/2009-03</uri>
    </claim>
    <claim>
        <name>windowsaccountname</name>
        <namespace>http://schemas.microsoft.com/ws/2008/06/identity/claims<
/namespace>
        <uri>http://schemas.microsoft.com/ws/2008/06/identity/claims
/windowsaccountname</uri>
    </claim>

```

ECAS ACCEPTANCE environment

All examples on this page refer to the *ECAS ACCEPTANCE* environment: <https://ecasa.cc.cec.eu.int:7002/cas>. The ECAS ACCEPTANCE environment is our recommended approach for integrating a new system with ECAS via the claims-based protocol.

ECAS ACCEPTANCE is accessible on the Internet. It is also managed like a production system, which for instance implies scheduling of all interventions.

All concepts described above remain valid for ECAS ACCEPTANCE. Parameters such as URLs and certificates will however need to be changed.

The parameters for ECAS ACCEPTANCE are as follows:

ECAS URL	https://ecasa.cc.cec.eu.int:7002/cas (internal) https://ecas.acceptance.ec.europa.eu/cas (external)
Metadata URL	https://ecasa.cc.cec.eu.int:7002/cas/adfs/federationmetadata/ecasa-cc-cec-eu-int_7002.xml (internal) https://ecas.acceptance.ec.europa.eu/cas/adfs/federationmetadata/ecas-acceptance-ec-europa-eu.xml (external)
Signing certificate	• Acceptance_STS_signature.cer • non_prod_ca.cer

ECAS Mockup Server

We provide an ECAS Mockup Server (available [here](#)) that you can use for testing purposes. It implements claims-based authentication but it requires that we generate a certificate for the host you will be using.